

REPORTE EJECUTIVO DE GESTIÓN DE RIESGOS

Clínica privada - Evaluación realizada con SimpleRisk
Seguridad de Sistemas - Licenciatura en Ciencias de la Computación

1. Resumen ejecutivo

Se realizó una evaluación de riesgos sobre el escenario de una clínica privada con 120 empleados y aproximadamente 800 pacientes atendidos por día. La organización depende de sistemas que procesan historias clínicas digitales, información de obras sociales y datos de facturación. El análisis identificó siete riesgos relevantes vinculados principalmente con la confidencialidad, integridad y disponibilidad de la información, además de aspectos operativos, legales y de terceros.

Los riesgos de mayor prioridad se relacionan con ransomware, compromiso de credenciales, pérdida o corrupción de datos, acceso no autorizado a bases de datos y caída de infraestructura de red. Se recomienda priorizar controles preventivos y de recuperación que reduzcan tanto la probabilidad de incidentes como su impacto sobre la atención de pacientes.

Amenaza externa: a modo de analogía, el escenario puede representarse con el Lobo Feroz y Caperucita Roja: una amenaza externa busca aprovechar una oportunidad o debilidad para alcanzar un activo valioso. La clínica debe asumir que existen actores externos capaces de intentar explotar vulnerabilidades y preparar controles antes de que el incidente ocurra.

2. Riesgos identificados

ID	Riesgo	P	I	Valor	Nivel
R01	Ataque de ransomware al sistema de historias clínicas	4	5	20	Crítico
R02	Acceso no autorizado mediante credenciales comprometidas	4	5	20	Crítico
R03	Pérdida o corrupción de datos clínicos	3	5	15	Alto
R04	Caída de la infraestructura de red de la clínica	3	4	12	Alto
R05	Acceso no autorizado a la base de datos clínica	3	5	15	Alto
R06	Divulgación accidental de información clínica	3	4	12	Alto
R07	Interrupción de servicios de un proveedor tecnológico	3	4	12	Alto

Escala académica: 1-4 Bajo; 5-9 Medio; 10-16 Alto; 17-25 Crítico. P e I corresponden a la valoración académica en escala 1-5 utilizada para justificar probabilidad e impacto. SimpleRisk fue configurado con el método Classic y puede presentar su puntuación interna en una escala diferente; por ello ambas valoraciones deben interpretarse de forma separada.

3. Top 5 de riesgos prioritarios

Prioridad	Riesgo	Valor	Respuesta prioritaria
1	R01 - Ransomware	20	EDR, MFA, segmentación, parches y backups inmutables.
2	R02 - Credenciales comprometidas	20	MFA, mínimo privilegio, bloqueo y monitoreo de accesos.
3	R03 - Pérdida/corrupción de datos	15	Backups automatizados, pruebas de restauración y redundancia.
4	R05 - Acceso no autorizado a BD	15	MFA administrativo, cifrado, permisos mínimos y monitoreo.
5	R04 - Caída de red	12	Redundancia, UPS, monitoreo y procedimientos de recuperación.

4. Estado de los planes de acción

Se definieron planes de mitigación asociados a riesgos prioritarios. Los planes se encuentran inicialmente en estado Mitigation Planned, con avance inicial del 0 %, y tienen como responsable al Analista de riesgos.

Riesgo	Plan	Vencimiento	Presupuesto	Estado
R01	Fortalecimiento contra ransomware	09/10/2026	\$0-\$100.000	Planificado
R02	Fortalecimiento de autenticación y accesos	09/10/2026	\$0-\$100.000	Planificado
R03	Protección y recuperación de datos clínicos	09/10/2026	\$0-\$100.000	Planificado

5. Tratamiento y defensa en capas

El tratamiento propuesto prioriza la mitigación. Como analogía, se utiliza la historia de Los Tres Cerditos: una defensa construida con una única barrera débil puede ser superada con facilidad, mientras que varias capas complementarias aumentan la resistencia. En la clínica, estas capas incluyen MFA, EDR, segmentación de red, mínimo privilegio, monitoreo, copias de seguridad aisladas, redundancia y procedimientos de respuesta y recuperación.

La estrategia no debe depender de un solo control. Por ejemplo, los backups reducen el impacto del ransomware, pero deben complementarse con prevención, detección, segmentación y pruebas periódicas de restauración.

6. Recomendaciones prioritarias al directorio

1. Identidad y acceso: implementar MFA para accesos sensibles y administrativos, aplicar mínimo privilegio y revisar periódicamente usuarios, roles y permisos.
2. Protección contra ransomware: desplegar EDR, mantener un proceso de parchado, segmentar la red y realizar capacitación periódica frente a phishing.
3. Resiliencia de datos: mantener copias automatizadas, aisladas e inmutables, acompañadas de pruebas de restauración y controles de integridad.
4. Disponibilidad: incorporar redundancia en infraestructura crítica, UPS, monitoreo de red y procedimientos documentados de recuperación.
5. Proveedores: establecer SLA, evaluar periódicamente terceros críticos y definir alternativas o contingencias ante indisponibilidad.
6. Monitoreo: registrar y revisar accesos a sistemas y bases de datos, generando alertas ante comportamientos anómalos.
7. Seguridad física del centro de datos: los centros de datos nunca deberían ubicarse junto a cocinas ni debajo de piscinas, debido a los riesgos de incendio e inundación.

7. Conclusión

La evaluación evidencia que la continuidad de la atención clínica depende directamente de la protección de los sistemas y de la información médica. La prioridad inmediata debe concentrarse en los riesgos R01 y R02, seguida por la protección de datos, bases de datos e infraestructura de red. La aplicación coordinada de los planes propuestos permitirá reducir la exposición y mejorar la capacidad de prevención, detección, respuesta y recuperación de la organización.

Documento preparado para el Directorio de la Clínica
Trabajo Práctico - Gestión de Riesgos con SimpleRisk